

S7 L2

Obiettivo

Sfruttare la vulnerabilità relativa al servizio Telnet su una macchina Metasploitable utilizzando Metasploit con il modulo `auxiliary/scanner/telnet/telnet_version`.

Prerequisiti

- Una macchina Kali Linux configurata con l'IP 192.168.1.25.
- Una macchina Metasploitable configurata con l'IP 192.168.1.40

STEPS:

- **Configurazione macchine**

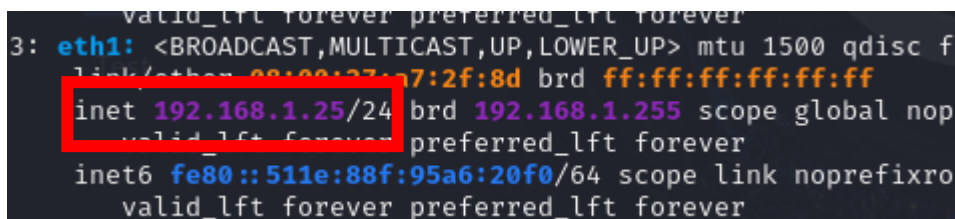
Kali linux

Apriamo il terminale di kali linux e digitiamo il comando

<**sudo ifconfig eth1 192.168.1.25 netmask 255.255.255.0**> per modificare l'indirizzo IP.

Nota: ho usato eth1 perché ci sono due schede di rete configurate sulla macchina Kali in uso.

Per verificare il cambio di IP possiamo usare il comando <**ip a**>

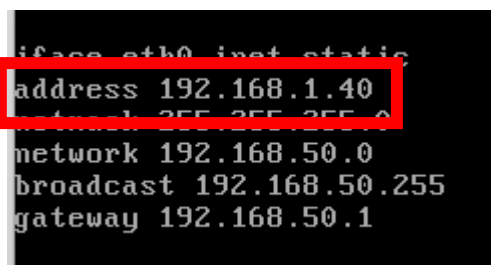


```
valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc f
    link/ether 08:00:27:17:2f:8d brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.25/24 brd 192.168.1.255 scope global nop
        valid_lft forever preferred_lft forever
    inet6 fe80::511e:88f:95a6:20f0/64 scope link noprefixro
        valid_lft forever preferred_lft forever
```

Metasploitable

Modifichiamo l'indirizzo IP della macchina all'interno del file **interfaces** presente nel path **/etc/network/**.

Per fare questo, usiamo il comando <**sudo nano /etc/network/interfaces**> e modifichiamo la voce address con l'IP 192.168.1.40



```
iface eth0 inet static
    address 192.168.1.40
    netmask 255.255.255.0
    network 192.168.50.0
    broadcast 192.168.50.255
    gateway 192.168.50.1
```

Per attivare le modifiche dobbiamo riavviare la scheda di rete tramite il comando

<**sudo /etc/init.d/networking restart**> (in alternativa possiamo riavviare la macchina)

Controlliamo l'IP della macchina metasploitable con il comando `<ip a>`

```
eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> m
link/ether: 08:00:27:21:67:1a brd ff:ff:f
inet 192.168.1.40/24 brd 192.168.50.255
inet6 fe80::a00:2711:fe24:671a/64 scope
```

- **Ricerca e configurazione dell'exploit su Metasploit**

Apriamo metasploit tramite il comando `<msfconsole>` e usiamo la keyword `<search>` per cercare il modulo **auxiliary telnet_version**.

```
0 auxiliary/scanner/telnet/lantronix_telnet_version
Detection
1 auxiliary/scanner/telnet/telnet_version
```

Dei due moduli presenti selezioniamo il secondo usando la keyword `<use>` seguito dal numero di riga del modulo che ci interessa, in questo caso 1.

```
msf6 > use 1
msf6 auxiliary(scanner/telnet/telnet_version) > █
```

Usiamo `<show options>` per controllare quali parametri sono richiesti all'exploit per funzionare.

Name	Current Setting	Required
PASSWORD		no
RHOSTS		yes
RPORT	23	yes
THREADS	1	yes
TIMEOUT	30	yes
USERNAME		no

Il requisito da impostare è rhosts. Per farlo usiamo il comando `<set rhosts [IP Target]>` in questo caso l'IP è quello della metasploitable ovvero 192.168.1.40.

Controlliamo nuovamente le impostazioni con `<show options>`

PASSWORD		no
RHOSTS	192.168.1.40	yes

- **Uso dell'exploit**

Finite tutte le configurazioni, mandiamo in esecuzione l'exploit tramite il comando **<telnet 192.168.1.40>**

```
msf6 auxiliary(scanner/telnet/telnet_version) > telnet 192.168.1.40  
[*] exec: telnet 192.168.1.40
```

Trying 192.168.1.40 ...
Connected to 192.168.1.40.
Escape character is '^]'.

m e t a s p l o i t a b l e

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login:

Inserite le credenziali eseguiamo il comando **<ip a>** per controllare se siamo nella macchina corretta.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:24:67:1a brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.40/24 brd 192.168.50.255 scope global eth0
    inet6 fe80::a00:27ff:fe24:671a/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```